

Automated VAPT Framework for Web Applications

Ram Karthik G, Tamizh Selvi
CH.SC.U4VYS23037, CH.SC.U4CYS23019
Department of Cybersecurity
Amrita Vishwa Vidyapeetham, Chennai

Abstract

Web applications are the foundation of the internet. They support things like online banking, shopping, education and healthcare. However, they have become very complicated. That has made them more vulnerable to attacks. There are types of vulnerabilities, such as SQL injection and cross-site scripting that can be used to harm web applications.

Existing tools that scan for vulnerabilities often rely on signature-based detection or third-party engines, which can result in false positives and limited understanding of the context. This project presents a custom web vulnerability scanner that uses heuristic-based detection algorithms to find types of vulnerabilities without relying on external tools.

The system includes a -page crawler, a parameter-aware injection engine and response similarity analysis. It also uses timing analysis and content-length comparison to detect vulnerabilities. The vulnerabilities are grouped into categories scored using a custom model and mapped to the OWASP Top 10 categories.

Introduction

Web application security is very important because many people use the internet to do sensitive things like banking and shopping. Web applications have to be secure to protect people's information. Even with good coding practices vulnerabilities can still happen.

There are types of vulnerabilities, including SQL injection and cross-site scripting. These can be used by hackers to get into the system and cause trouble. Traditional tools for finding vulnerabilities are not very good at detecting these types of attacks.

The problem is that traditional tools rely much on looking for specific patterns. They do not understand the context of the vulnerability so they can miss things or give alarms. They are also closed systems so it is hard to understand how they work.

Some of the challenges in web application security include the increasing complexity of web architectures and the need for context- vulnerability detection. There is also a trade-off between positives and false negatives and a lack of transparency in automated tools.

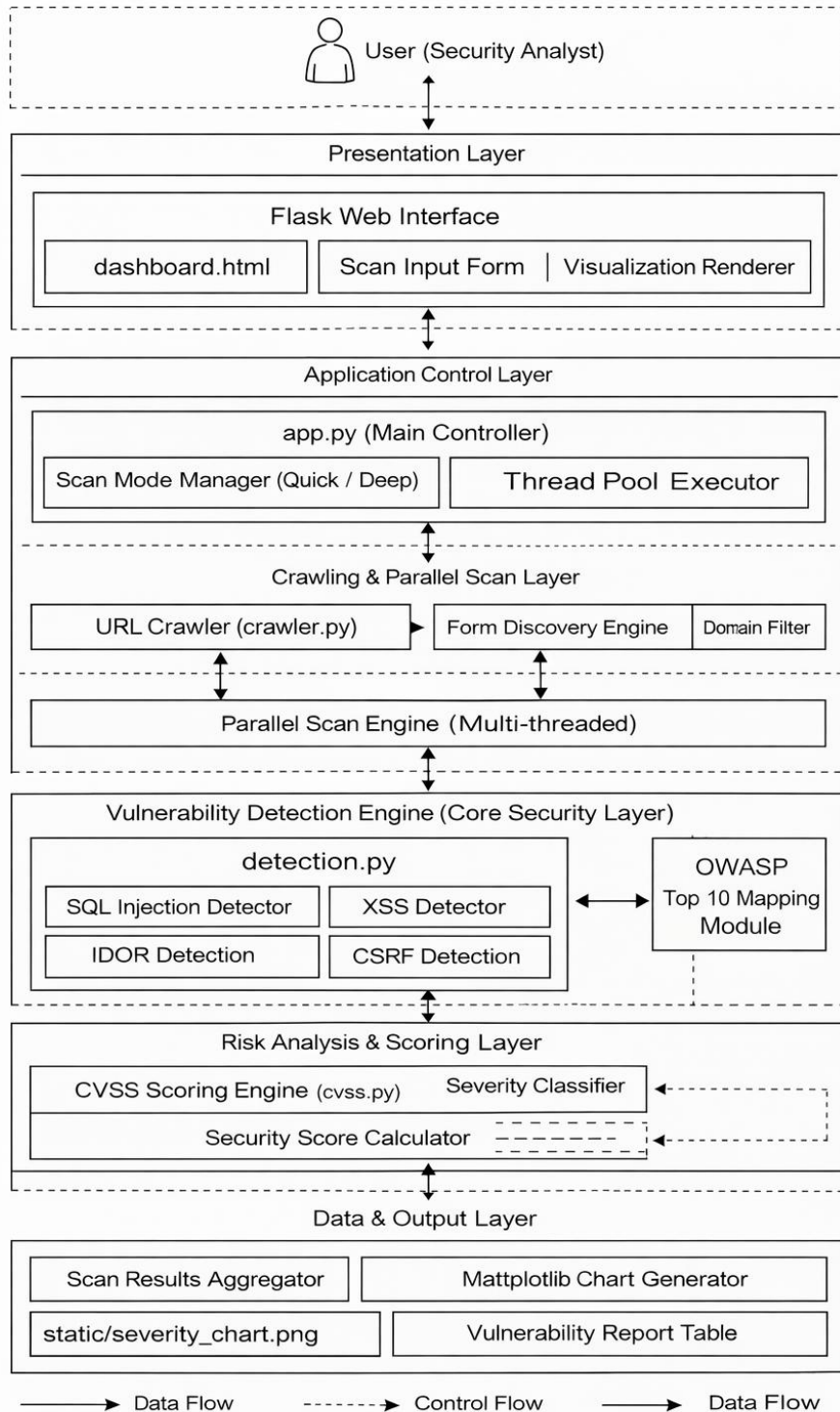
To solve these problems, we need to use approaches like heuristic-based detection and response-differential analysis. We also need to use scoring models, like CVSS to evaluate the severity of vulnerabilities.

The proposed system is a type of web vulnerability scanner that uses these approaches. It is made up of parts including a multi-page crawler and a parameter-aware injection engine. The scanner performs response similarity analysis, timing measurement and content-length comparison to detect vulnerabilities. It also uses a CVSS-based model to score vulnerabilities and map them to OWASP Top 10 categories.

The goal of the system is to provide a multi-engine web vulnerability scanner that is accurate, efficient and easy to use. It emphasizes transparency and contextual detection and it is designed to be used in educational research and foundational security analysis.

Architecture

Web-Based Vulnerability Scanner – System Architecture



Algorithm

Algorithm: WEB_VULNERABILITY_SCANNER

Input: u_0 (Target URL), $M \in \{quick, deep\}$

Output: V (Vulnerabilities), S (Security Score)

Begin **if** $M = quick \rightarrow (L \leftarrow 5, k \leftarrow 3)$ **else** $(L \leftarrow 15, k \leftarrow 5)$
 $U \leftarrow \emptyset$; $V \leftarrow \emptyset$; $Q \leftarrow \{u_0\}$
 while $Q \neq \emptyset \wedge |U| < L$:
 $u \leftarrow \text{pop}(Q)$
 if $\text{domain}(u) = \text{domain}(u_0)$:
 $U \leftarrow U \cup \{u\}$
 $Q \leftarrow Q \cup (\text{EXTRACT_LINKS}(u) - U)$
 $\forall u \in U$ **parallel** (k threads):
 $\forall p \in P$:
 if $\text{DETECT}(u, p) \rightarrow V \leftarrow V \cup \{v\}$
 $\forall v \in V$:
 $\text{CVSS}(v) \leftarrow 6I(v) + 4E(v)$
 $\forall v \in V$:
 $\text{CVSS}(v) \leftarrow 6I(v) + 4E(v)$
 $S \leftarrow 100 - ((\sum_{v \in V} \text{CVSS}(v)) / |V| \times 10)$
End **return** (V, S)

Time Complexity:

$$T(n) = O((n \cdot p) / k)$$

Space Complexity:

$$O(n + |V_i|)$$

Time Complexity:

$$T(n) = O((n \cdot p) / k)$$

Space Complexity:

$$O(n + |V|)$$